

Laboratorio de Seguridad de Redes con FortiGate

Documentación Técnica Profesional

Estudiante: Edwin De Paula
Matrícula: 2024-2415
Institución: Instituto Tecnológico de las Américas (ITLA)
Asignatura: Seguridad de Redes
Carrera: Seguridad Informática

Repositorio: github.com/edwindepaula10/FortiGate-Network-Security-Lab-2024-2415
Video demostrativo: youtu.be/nt-jFLaIQJU

1. Objetivo de la Red

Diseñar y configurar, en su totalidad por interfaz gráfica (GUI), una topología de red segura utilizando FortiGate como firewall perimetral e interno. La red segmenta el tráfico entre una LAN de usuarios y una LAN de servidores, permite salida controlada a Internet mediante NAT, y aplica múltiples capas de seguridad: control de acceso por servicio, filtrado de aplicaciones, filtrado web, detección de escaneo de red y protección de aplicaciones web (WAF).

El direccionamiento IP de toda la topología se derivó de la matrícula del estudiante (2024-2415), utilizando la red base 10.24.15.0/24 : los dígitos 24 corresponden al año de ingreso y 15 a los últimos dos dígitos de la matrícula.

2. Topología de Red

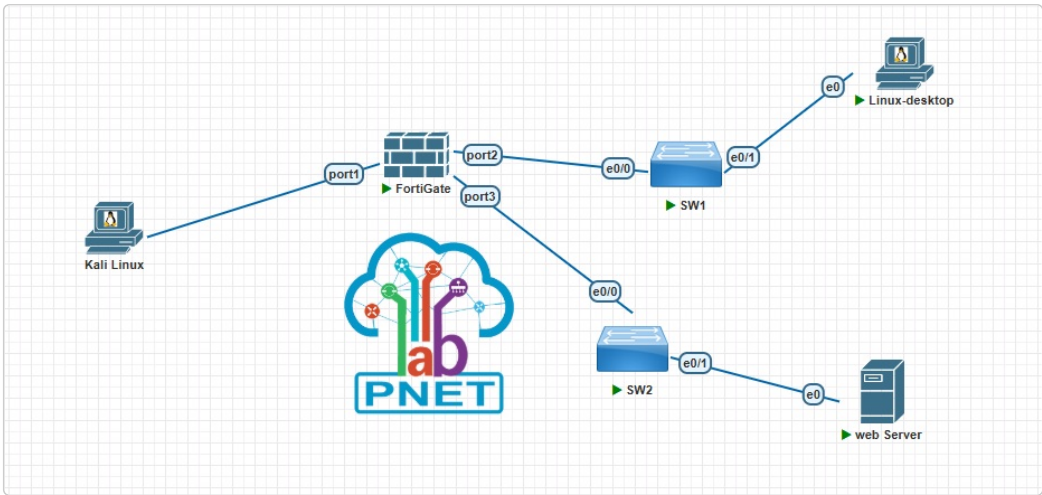


Figura 1 — Topología general del laboratorio (PNetLab)

2.1 Descripción de la topología

Nodo	Rol	Conexión
Kali Linux	Acceso a GUI del FortiGate / equipo de pruebas de escaneo	port1 (WAN) vía Cloud1 (VMware vmnet8)
FortiGate-VM64-KVM	Firewall / gateway	port1 (WAN), port2 (LAN Usuarios), port3 (LAN Servidores)
SW1	Switch LAN Usuarios	port2 ↔ Linux-Desktop
Linux-Desktop	Cliente de pruebas (DHCP, navegación, escaneo nmap)	SW1
SW2	Switch LAN Servidores	port3 ↔ web Server
web Server (Metasploitable2 + DVWA)	Servidor web de destino	SW2

2.2 Direccionamiento IP

Segmento / Interfaz	Red	Máscara	Gateway	Rango DHCP
WAN (port1)	Asignada por DHCP (vmnet8)	/24	Aprendido automáticamente	—
LAN Usuarios (port2)	10.24.15.0/25	255.255.255.128	10.24.15.1	10.24.15.10 - 10.24.15.100
LAN Servidores (port3)	10.24.15.128/28	255.255.255.240	10.24.15.129	No aplica (estática)
web Server	10.24.15.130	255.255.255.240	10.24.15.129	Estática

3. Configuración de Interfaces y DHCP

Configuración realizada en **Network > Interfaces** y **Network > DHCP Server** de la GUI del FortiGate.

Interfaz	Alias	IP/Netmask	Role	Admin Access
port1	—	DHCP (WAN)	—	PING, HTTPS, SSH, HTTP
port2	LAN_Usuarios	10.24.15.1/255.255.255.128	LAN	PING
port3	LAN_Servidores	10.24.15.129/255.255.255.240	LAN	PING

DHCP Server en port2: rango 10.24.15.10 – 10.24.15.100 , gateway entregado 10.24.15.1 , DNS heredado del sistema.

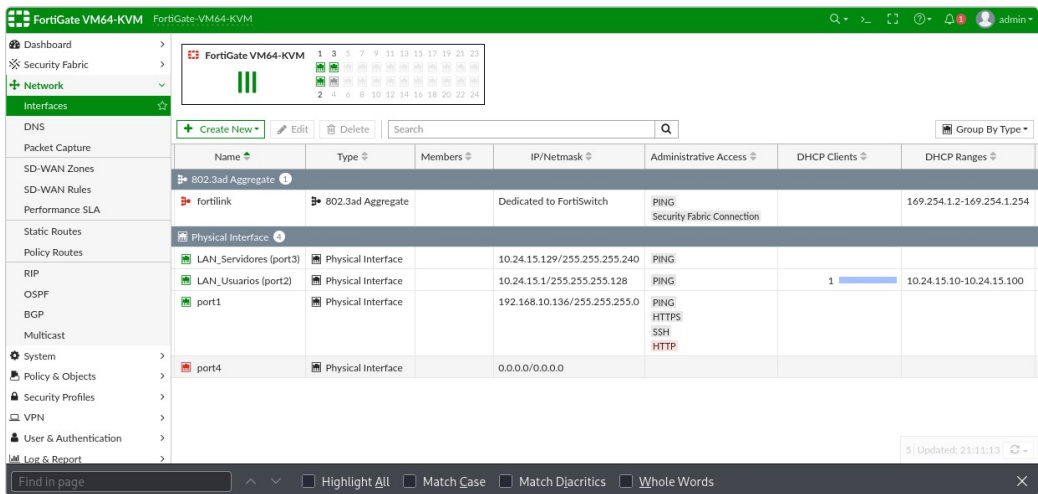


Figura 2 — Network > Interfaces: resumen de IP/Netmask, Administrative Access y rangos DHCP

4. Ruta por Defecto

El FortiGate aprendió automáticamente la ruta por defecto mediante el DHCP de `port1`, visible en **Network > Static Routes**.



Figura 3 — Ruta 0.0.0.0/0 habilitada, gateway 192.168.10.1 vía port1

5. NAT y Acceso a Internet

Política de firewall `Usuarios_a_Internet`, con NAT de origen habilitado (*Use Outgoing Interface Address*), permite la salida de la LAN de Usuarios hacia Internet.

Parámetro	Valor
Incoming / Outgoing	port2 / port1
Source / Destination	all / all
Service	ALL
NAT	Enable — Use Outgoing Interface Address

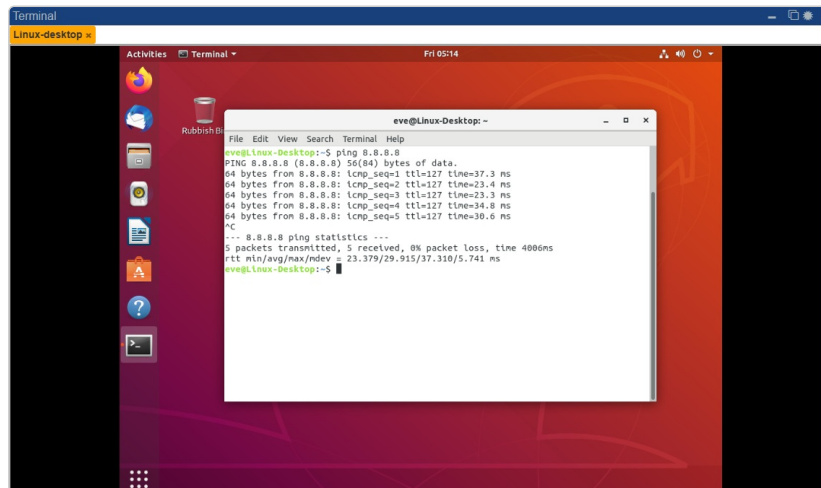


Figura 4 — Ping exitoso a 8.8.8.8 desde Linux-Desktop, confirma NAT funcionando

6. Control de Tráfico: solo HTTP entre LAN Usuarios y LAN Servidores

Se implementaron dos políticas explícitas evaluadas en orden estricto (FortiGate aplica la primera coincidencia de arriba hacia abajo):

Parámetro	Usuarios_a_Servidores_HTTP_Allow	Usuarios_a_Servidores_DENY_ALL
Incoming / Outgoing	port2 / port3	port2 / port3
Service	HTTP	ALL
Action	ACCEPT	DENY
Inspection Mode	Proxy-based	Flow-based
Orden	1 (arriba)	2 (abajo)

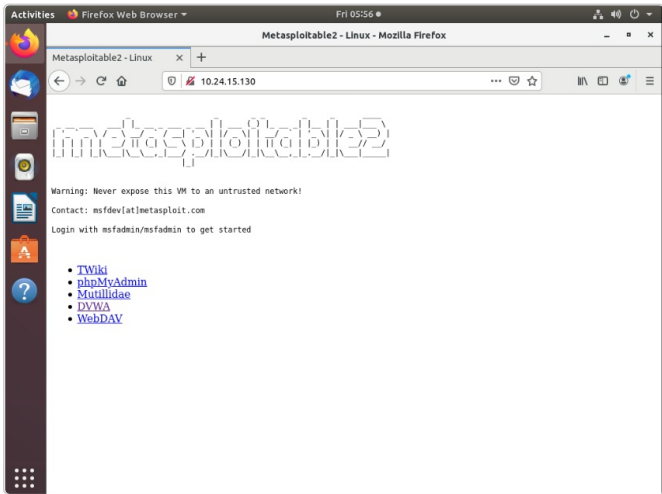


Figura 5 — HTTP permitido: página del servidor Metasploitable2 cargada desde el navegador

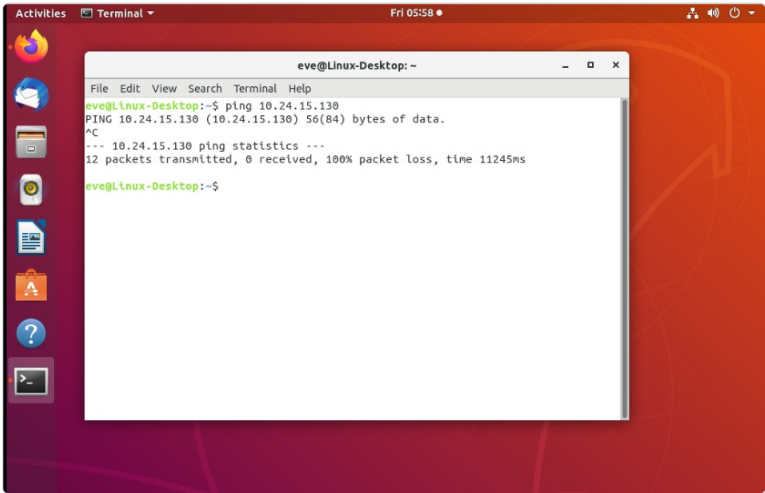


Figura 6 — Resto del tráfico bloqueado: ping hacia 10.24.15.130 con 100% de pérdida de paquetes

7. Application Control — Redes Sociales y Llamadas de WhatsApp

Perfil `Bloqueo_RedesSociales_WhatsApp` (Security Profiles > Application Control), aplicado a la política `Usuarios_a_Internet` junto con SSL Inspection (`certificate-inspection`).

Elemento	Acción
Categoría Social.Media	Block
Application Override: WhatsApp_VoIP.Call	Block

Se optó por bloquear la firma granular de llamadas (`WhatsApp_VoIP.Call`) en lugar de la aplicación completa, cumpliendo exactamente el requisito de bloquear llamadas sin afectar la mensajería de texto.

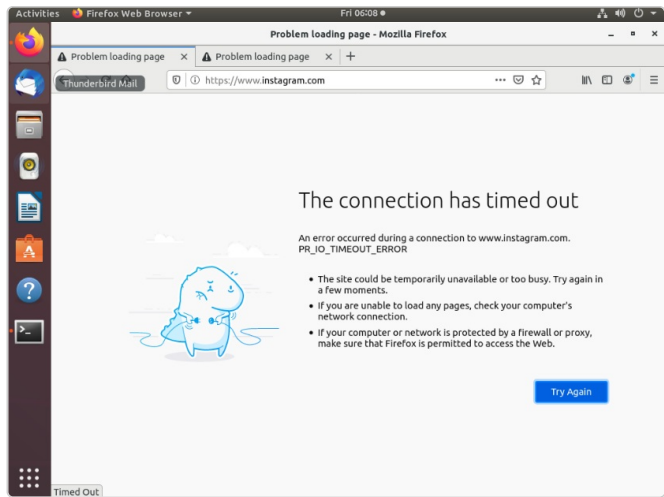


Figura 7 — Intento de acceso a Instagram: la conexión no se completa (bloqueo por Application Control con SSL Inspection)

La política de llamadas se validó a nivel de configuración (firma en modo Block). La demostración de una llamada real de WhatsApp no se ejecutó por una limitación de entorno detallada en la sección 11.

8. Web Filter — Bloqueo de itla.edu.do y Subdominios

Perfil **Bloqueo_ITLA** (Security Profiles > Web Filter > Static URL Filter):

URL	Tipo	Acción
itla.edu.do	Wildcard	Block
*.itla.edu.do	Wildcard	Block

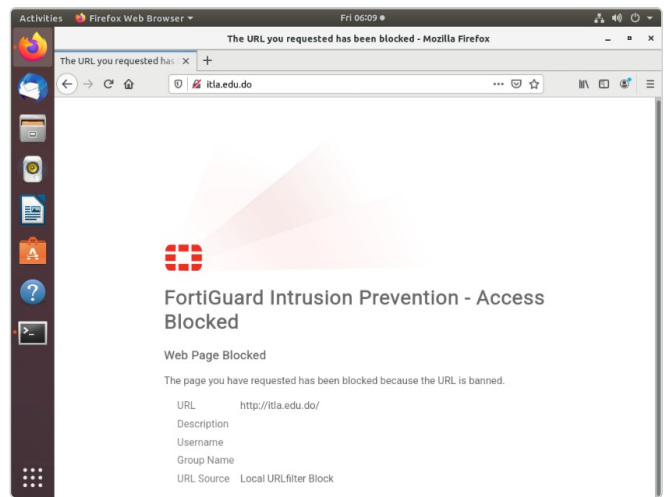


Figura 8 — Acceso a itla.edu.do bloqueado (FortiGuard, Local URL filter Block)

9. Detección y Bloqueo de Escáneres de Red

Implementado mediante **DoS Policy** (Policy & Objects > DoS Policy), perfil **AntiScan_Servidores**, que detecta el patrón de escaneo por anomalía de tráfico en lugar de depender de firmas IPS descargadas de FortiGuard.

Parámetro	Valor
Incoming Interface	port2
Anomalías activadas	tcp_port_scan, icmp_sweep → Block
Threshold	Ajustado por debajo del valor por defecto

Prueba ejecutada desde Linux-Desktop:

```
nmap -sS -Pn 10.24.15.130
```

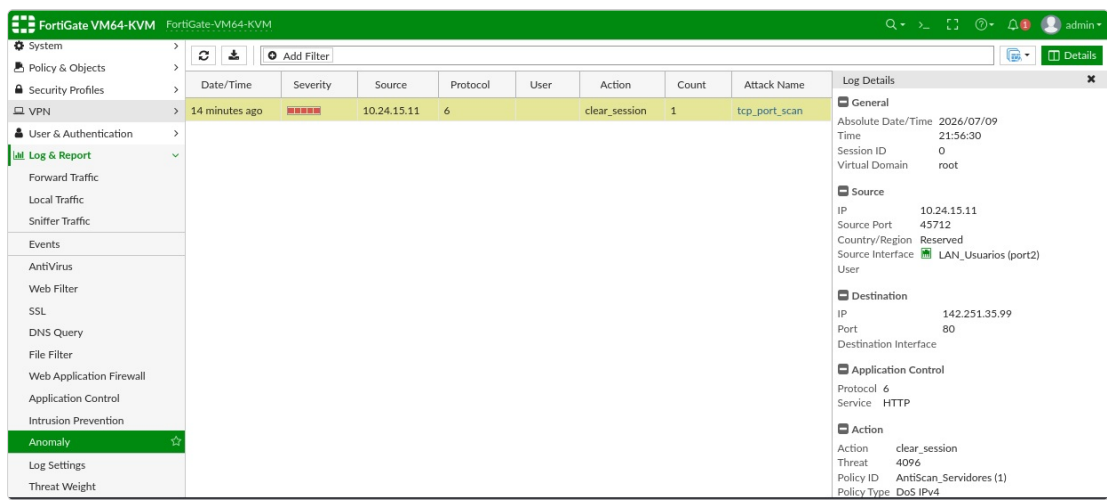


Figura 9 — Log & Report > Anomaly: evento tcp_port_scan detectado desde 10.24.15.11, acción clear_session

10. WAF — Protección del Servidor Web

WAF requiere modo de inspección Proxy-based, habilitado únicamente en la política `Usuarios_a_Servidores_HTTP_Allow` (en FortiOS 6.4.x el modo de inspección se configura por política individual, no de forma global).

Parámetro	Valor
Perfil	WAF_WebServer
Categorías	SQL Injection, Cross Site Scripting (XSS)
Sensibilidad	High
Aplicado a	Usuarios_a_Servidores_HTTP_Allow

Pruebas ejecutadas contra DVWA (`http://10.24.15.130/dvwa/`), con nivel de seguridad de la aplicación en "High" para exponer el patrón de ataque sin sanitización parcial:

```
SQL Injection: 1' OR '1'='1
XSS Reflected: <script>alert('test')</script>
```

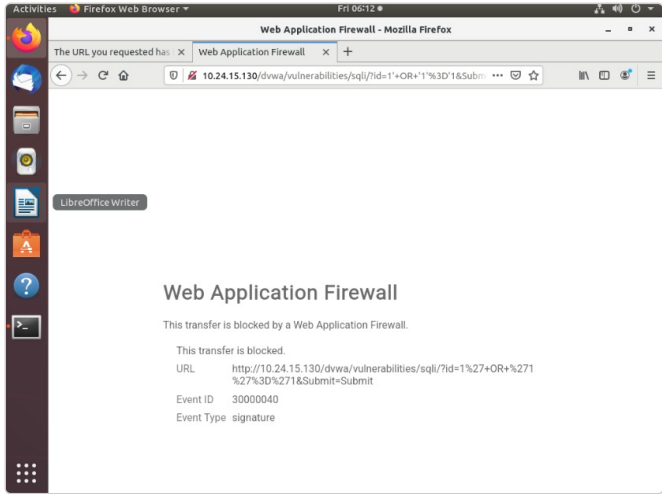


Figura 10 — Intento de SQL Injection bloqueado por el WAF (Event ID 30000040, tipo signature)

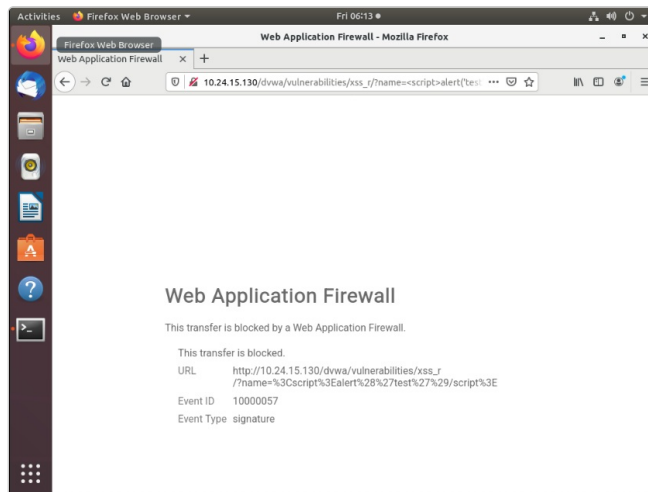


Figura 11 — Intento de XSS reflejado bloqueado por el WAF (Event ID 10000057, tipo signature)

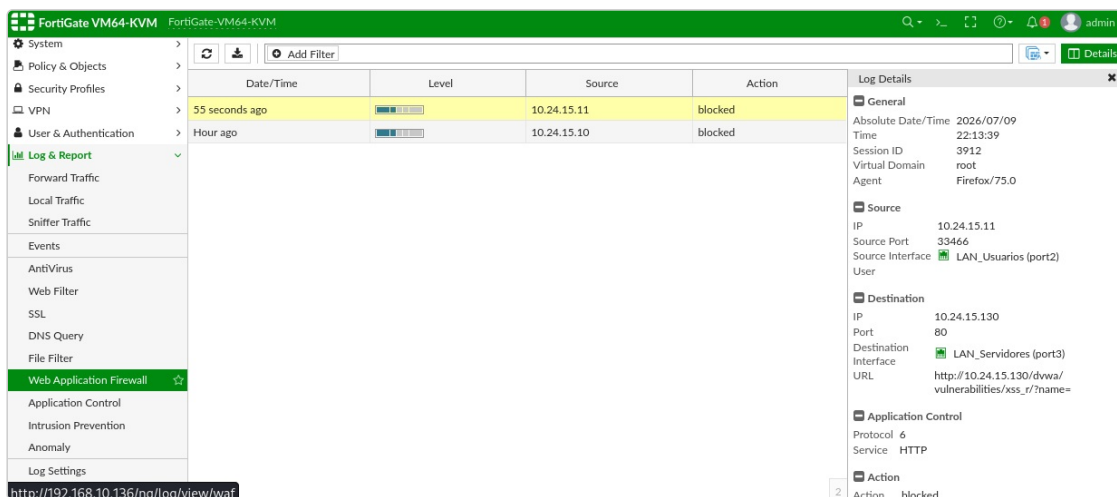


Figura 12 — Log & Report > Web Application Firewall: detalle del evento bloqueado (origen 10.24.15.11, destino 10.24.15.130:80)

11. Limitaciones Conocidas del Entorno

- **Acceso administrativo HTTPS a la GUI:** se identificó un bug de corrupción de paquetes TLS en el vNIC `e1000` emulado por VMware/PNetLab, que producía el error `SSL_ERROR_RX_RECORD_TOO_LONG` al acceder por HTTPS. Se utilizó HTTP (`allowaccess http`) para la administración durante el laboratorio.
- **Prueba en vivo de llamada de WhatsApp:** se intentó desplegar un nodo Windows 10 en PNetLab para instalar WhatsApp Desktop. La imagen disponible presentó un error de arranque (`0xc000000f`), atribuible a incompatibilidad de modo de arranque (UEFI/GPT) con la emulación BIOS Legacy del template QEMU de PNetLab. El bloqueo de llamadas queda demostrado mediante la firma `WhatsApp_VoIP.Call` configurada en modo Block (sección 7), verificable en la configuración aunque no se ejecutó una llamada real.

12. Credenciales de Laboratorio

Únicamente se documentan credenciales de servicios con valores por defecto públicamente conocidos. La contraseña de administrador del FortiGate no se incluye en este documento por buenas prácticas de seguridad.

Servicio	Usuario	Password
Metasploitable2 (consola)	msfadmin	msfadmin
DVWA (web)	admin	password
FortiGate GUI	admin	no documentada

13. Herramientas Utilizadas

- PNetLab — Plataforma de emulación de red
- FortiGate-VM64-KVM (FortiOS 6.4.6) — Firewall emulado
- Kali Linux — Acceso a GUI y pruebas de escaneo (nmap)
- Metasploitable2 + DVWA — Servidor web vulnerable para pruebas de WAF
- VMware Workstation — Virtualización del servidor PNetLab

14. Enlaces

Recurso	URL
Repositorio GitHub	https://github.com/edwindepaula10/FortiGate-Network-Security-Lab-2024-2415
Video demostrativo	https://youtu.be/nt-jFLaIOJU